

CLOUDORA

Security Incident Report

Cloudora Security Operations

Report ID	CLD-IR-0002
Related ticket	Reported phishing email impersonating Cloudora HR
Report title	Payroll-themed credential phishing campaign
Analyst	SOC Analyst
Date of report (UTC)	14/08/2026
Incident severity	P1
Status	Contained
Classification	CONFIDENTIAL - Internal and client distribution only

1. Executive summary

On 14 August 2026, There was an attack made through a payroll themed phishing email where the attacker had told employees "to confirm their payroll details by 5pm" or their pay would be held.This was done through a lookalike website.The attacker had used two message styles to carry this out where 1 email had failed all 3 of the authentication checks and the other email that presented a fake,lookalike domain that passes the authentication checks.This led to 6 employees clicking the website and 2 employees entering their passwords.The attacker then used the credentials to sign in to those accounts from Amsterdam the same day.After employees reported the email,the compromise was caught,the 2 accounts were contained,account password are reset so attacker cannot access accounts and emails are removed from mailboxes.Another marketing email was also reported and investigated however it was concluded as legitimate.There was no evidence of fraudulent payment or data theft in logs.Four further staff who clicked but did not enter credentials, and thirty who received the email but did not click are being contacted.

2. Incident timeline

Time (UTC)	Source	Event	Evidence / notes
Aug 25, 06:58	Message Trace	Legitamate Cloudora Newsletter delivered	Was investigated after being reported but was legitimate.
Aug 25,08:36	Message Trace	Phishing variant B sent to cloudora employees	Used a lookalike domain "cloudora-hr-portal.example" to pass all authentication checks
Aug 25,08:39	Message Trace	Phishing variant A sent to cloudora employees	Sent from "198.18.44.23".Used the spoofed email "payroll@cloudora.io" Reply email is different "hr-support@cloudora-hr-portal.example".Failed all authentication checks(spf,dkim and dmarc)
Aug 25,08:39	Message Trace	Seth Lane clicked the phishing link but did not submit credentials	Link was clicked but no credentials were submitted
Aug 25,08:47	Message Trace	Freya Lynn clicked the phishing link and submitted credentials	Variant A was clicked and credentials submitted to it..Attacker has access to credentials
Aug 25,09:05	Message Trace	Ryan Boyd clicked the phishing link and submitted credentials	Variant B was clicked and credentials submitted to it.Attacker has access to credentials
Aug 25,09:11	Ticket	Phishing incident reported to SOC	James.holt forwards the phish to the SOC; ticket CLD-0002 raised, investigation starts
Aug 25,09:58	Message Trace	Hugo Marsh clicked the phishing link but	Link was clicked but no credentials were

		did not submit credentials	submitted
Aug 25,10:12	Message Trace	Chloe Price clicked the phishing link but did not submit credentials	Link was clicked but no credentials were submitted
Aug 25,11:47	Message Trace	Dina Said clicked the phishing link but did not submit credentials	Link was clicked but no credentials were submitted
Aug 25,10:34	Sign In Logs	Attacker signs into Freya Lynn's account	Attacker signs into account from 198.18.7.200 in Amsterdam on a windows 11 and goes on Chrome for Microsoft 365 at 10:34,Outlook at 10:36 and Sharepoint at 10:41
Aug 25,13:22	Sign In Logs	Attacker signs into Ryan Boyd's account	Attacker signs into account from 198.18.7.200 in Amsterdam on Windows 11 and goes on Chrome for Microsoft 365 at 13:22,Outlook at 13:25.
Aug 25,14:00	Response	Containment executed on both accounts	See section 7

3. Findings

Finding 1 A payroll-themed phishing campaign was delivered to staff

On 25 August 2026,40 mailboxes were sent out targeting Cloudora employees with the subject written as 'Payroll update: action required before 5pm' and 'Action required: confirm your August payroll details'.4 recipients had the copies quarantined however, 36 recipients still received atleast one copy.

Finding 2 The campaign used two authentication tactics

2 variants were used in the campaign,Variant A and Variant B.Variant A consists of a spoofed email "payroll@cloudora.io",the reply email being a different email set as "hr-support@cloudora-hr-portal.example", the authentication checks for spf,dkim and dmarc failing and the emails being sent from "198.18.44.23".Variant B uses a lookalike domain "cloudora-hr-portal.example" and passes the authentication checks for spf,dkim and dmarc however this is for its lookalike domain and not for Cloudora.Authentication only proves the sending domain, not its legitimacy

Finding 3 Two accounts submitted credentials

Credentials for "freya.lynn@cloudora.io" and "ryan.boyd@cloudora.io" were submitted with link being clicked at 08:47 and 09:05 and CredentialsSubmitted=Yes.Both accounts were signed in from 198.18.7.200 in Amsterdam on a Windows 11/Chrome device.Freya had signed in the morning at Manchester as well making it impossible travel if she signed in again in amsterdam at 10:34.Same for Ryan at 13:22.Attacker had accessed Microsoft 365 at 10:34,Outlook at 10:36 and Sharepoint at 10:41 on Freya's account and accessed Microsoft 365 at 13:22 and Outlook at 13:25 on Ryan's.This is use of harvested valid credentials (T1078). The Sessions on the account are revoked,they are given a password resets and MFA is re-registered.

Finding 4 Four staff clicked but did not submit credentials

Seth Lane, Hugo Marsh, Chloe Price and Dina Said had also clicked the linked at 08:39, 09:58, 10:12 and 11:47 however none of them had submitted their credentials(CredentialsSubmitted=No).They are not confirmed compromised, but a click means they reached the harvesting page; they are treated as elevated risk pending a precautionary password reset and a direct check-in.

Finding 5 Thirty staff received the phish but did not click

30 staff had also received the emails but did not click and form the near-miss list for user communicatioons.Additionally,4 more employees,Emma Hayes, Maya Chen, Nina Cole and Ruth Dean were also targetted but had every copy quarantined by Exchange Online Protections.

Finding 6 The reported newsletter is legitimate

The Cloudora Newsletter was also reported and investigated.The email passed all the authentication checks for SPF,DKIM and DMARC, used the legitimate "cloudora.io" domain and was sent through mailchimp which is authorized by Cloudora to send emails.Therefore,the newsletter was confirmed legitimate and cleared as a false positive.

4. Indicators of compromise (IOCs)

Type	Value	Context
Domain	cloudora-hr-portal.example	Lookalike of cloudora.io; phishing / credential harvesting; subdomains mail., mailer., login .
URL	hxxps://cloudora-hr-portal[.]example/payroll/login	Variant A harvesting link (defanged)
URL	hxxps://login.cloudora-hr-portal[.]example/verify	Variant B harvesting link (defanged)
IPv4	198.18.44.10	Variant A wave-1 sending relay + harvest host (Amsterdam)
IPv4	198.18.44.23	Variant A wave-2 sending relay (same /24)
IPv4	198.18.51.7	Variant B sending relay
IPv4	198.18.7.200	Attacker sign-in IP (Amsterdam) - harvested credential use; blocked
Sender	r payroll@cloudora.io (spoofed)	Forged From on variant A; Reply-To hr-support@cloudora-hr-portal.example
Subject	Payroll update: action required before 5pm	Variant A
Subject	Action required: confirm your August payroll details	Variant B

5. MITRE ATT&CK; mapping

Tactic	Technique ID	Technique name	Evidenced by
Initial Access	T1566.002	Phishing: Spearphishing Link	Findings 1-2, the two phishing variants and their links
Credential Access	T1598.003	Phishing for Information: Spearphishing Link	The credential-harvesting page behind the link
Initial Access	T1078.004	Valid Accounts: Cloud Accounts	Finding 3, attacker sign-ins with harvested credentials

Context technique (infrastructure): the attacker registered and hosted a lookalike domain (T1583.001, Acquire Infrastructure: Domains). Mapped for awareness; not directly evidenced in these logs beyond the domain itself.

6. Scope

Accounts confirmed compromised (2)

"freya.lynn@cloudora.io" (attacker sign-in 10:34:20 UTC) and "ryan.boyd@cloudora.io" (13:22:05 UTC), both 25 Aug, both from 198.18.7.200; both submitted credentials to the phishing page.

Accounts clicked but not confirmed compromised (4)

seth.lane, chloe.price, hugo.marsh, dina.said - clicked the link, no credentials submitted, no anomalous sign-in. Precautionary reset and direct check-in.

Accounts targeted but not compromised (34)

Thirty received the phish and did not click (near-miss, user comms). Four more (emma.hayes, maya.chen, nina.cole, ruth.dean) had every copy quarantined by EOP. Full near-miss list is produced by the Task 2 query.

Accounts investigated and cleared (false positives) (1)

The “Cloudora Monthly” Mailchimp newsletter (Finding 6).

7. Actions taken

Order	Action	Why this order matters
1	Revoked all active sessions and refresh tokens for freya.lynn and ryan.boyd	Kills the attacker's live sessions immediately; a reset alone leaves an open session working
2	Reset credentials for both compromised accounts	New passwords only matter once the stolen sessions are dead
3	Required and re-registered MFA on both accounts	MFA stops a harvested password being enough next time
4	Blocked infrastructure: 198.18.44.10, 198.18.44.23, 198.18.51.7, 198.18.7.200 and cloudora-hr-portal.example (all subdomains) at mail gateway and web proxy	Cuts off sending, hosting and the login IP
5	Purged delivered phishing messages from all mailboxes	Stops anyone else clicking a copy that is still sitting in an inbox
6	Verified: re-ran the victim sign-in and attacker-IP pivot queries; no 198.18.7.200 activity after containment	Containment is a claim until you prove it in the logs

8. Recommendations

- Precautionary password resets and a direct check-in for the four clicked-but-no-credential staff; user communications and awareness for the thirty near-miss recipients (see the client comms draft in the answer key)
- Enforce MFA on all accounts and disable legacy authentication that bypasses it; both compromises were password-only.
- Move cloudora.io DMARC policy to p=reject so spoofing variants like variant A are rejected outright, not merely quarantined, and downstream recipients reject them too.
- Add mail-gateway detection for newly-registered lookalike domains and for external mail whose From is cloudora.io but which fails DMARC.
- Deploy the sign-in detection from Task 4: a successful sign-in from a new country within a few hours of a phishing-link click. This would have flagged both compromises the same morning.
- Block the phishing infrastructure permanently and monitor for the actor re-registering adjacent lookalike domains.

9. Lessons learned

Staff reporting caught this: the first forwarded email opened the ticket before automated detection did, which argues for keeping the report button prominent and praised. The message trace turned a single reported email into full campaign scope in minutes, and pivoting on the attacker sign-in IP surfaced the second victim immediately - never stop at victim one. The false positive mattered as much as the phish: variant B and the Mailchimp newsletter both pass authentication, and only checking which domain they pass for tells them apart. The gap to close is detection speed: both compromises were visible in the logs within an hour of the clicks, and a click-then-foreign-login rule would have alerted automatically rather than waiting on a human report.